

Lista de verificación de controles y cumplimiento

Para completar la lista de verificación de evaluación de controles, consulte la información proporcionada en el [informe de alcance, objetivos y evaluación de riesgos](#). Para obtener más detalles sobre cada control, incluidos el tipo y el propósito, consulte el documento de [categorías de control](#).

Luego, seleccione “sí” o “no” para responder a la pregunta: *¿Tiene Botium Toys actualmente este control implementado?*

Lista de verificación de evaluación de controles

Sí	No	Control
☐	☒	Privilegio mínimo
☒	☐	Planes de recuperación ante desastres
☐	☒	Políticas de contraseñas
☒	☐	Separación de funciones
☒	☐	Cortafuegos (Firewall)
☐	☒	Sistema de detección de intromisiones (IDS)
☐	☒	Copias de seguridad (Backups)
☒	☐	Software antivirus
☒	☐	Monitoreo manual, mantenimiento e intervención para sistemas heredados
☐	☒	Cifrado
☐	☒	Sistema de gestión de contraseñas
☒	☐	Cerraduras (oficinas, tienda, almacén)

- | | | |
|-------------------------------------|--------------------------|---|
| ☒ | ☐ | Vigilancia por circuito cerrado de televisión (CCTV) |
| ☒ | ☐ | Detección/prevención de incendios (alarma de incendio, sistema de rociadores, etc.) |

Para completar la lista de verificación de cumplimiento, consulte la información proporcionada en el [informe de alcance, objetivos y evaluación de riesgos](#). Para obtener más detalles sobre cada regulación de cumplimiento, revise la lectura sobre [controles, marcos de trabajo y cumplimiento](#).

Luego, seleccione “sí” o “no” para responder a la pregunta: *¿Cumple Botium Toys actualmente con esta buena práctica de cumplimiento?*

Lista de verificación de cumplimiento

Payment Card Industry Data Security Standard (PCI DSS)

- | Sí | No | Buena práctica |
|-------------------------------------|-------------------------------------|---|
| ☐ | ☒ | Solo los usuarios autorizados tienen acceso a la información de tarjetas de crédito de los clientes. |
| ☐ | ☒ | La información de tarjetas de crédito se almacena, acepta, procesa y transmite internamente en un entorno seguro. |
| ☒ | ☐ | Implementar procedimientos de cifrado de datos para proteger mejor los puntos de contacto y los datos de las transacciones con tarjetas de crédito. |
| ☒ | ☐ | Adoptar políticas seguras de gestión de contraseñas. |

General Data Protection Regulation (GDPR)

- | Sí | No | Buena práctica |
|--------------------------|-------------------------------------|---|
| ☐ | ☒ | Los datos de los clientes de la U.E. se mantienen privados/seguros. |

- | | | |
|-------------------------------------|-------------------------------------|--|
| ☒ | ☐ | Existe un plan para notificar a los clientes de la U.E. dentro de las 72 horas si sus datos se ven comprometidos o hay una violación de seguridad. |
| ☐ | ☒ | Asegurarse de que los datos estén clasificados e inventariados correctamente. |
| ☒ | ☐ | Hacer cumplir las políticas, procedimientos y procesos de privacidad para documentar y mantener los datos de manera adecuada. |

System and Organizations Controls (SOC type 1, SOC type 2)

- | Sí | No | Buena práctica |
|-------------------------------------|-------------------------------------|--|
| ☒ | ☐ | Se han establecido políticas de acceso de usuarios. |
| ☐ | ☒ | Los datos sensibles (PII/SPII) son confidenciales/privados. |
| ☐ | ☒ | La integridad de los datos garantiza que la información sea consistente, completa, precisa y haya sido validada. |
| ☒ | ☐ | Los datos están disponibles para las personas autorizadas a acceder a ellos. |

Esta sección es *opcional* y se puede utilizar para proporcionar un resumen de recomendaciones al gerente de TI sobre qué controles o buenas prácticas de cumplimiento necesita implementar Botium Toys, según el riesgo que implique no hacerlo a tiempo.

Recomendaciones (opcional): En esta sección, proporcione recomendaciones relacionadas con las necesidades de control o cumplimiento que su gerente de TI podría comunicar a las partes interesadas para reducir los riesgos en los activos y mejorar la postura de seguridad de Botium Toys.

Recomendacion:

De primero y urgencia aplicar el principio del menor privilegio para asegurar que las cuentas de los clientes esten sefguras y solo en las manos correctas

De segundo mejorar el sistema de incriotacion auno confiable , probado y complejo para asegurar los activos presentes

De tercero tener un factor de multiautentifisacion para asegurar contraseñas y la gestion de las mismas

Y por cuarto implementar un sistema automatico de backups en una nube segura y cifrada